Accel Business: privacy and security note

Team RNG, Project Udyam Digital. A prototype on synthetic data, handled as if it were real. Each statement describes the code in this repository. This is an engineering note, not legal advice.

Position under the DPDP Act 2023. Accel Business is the Data Fiduciary, and the owner or signatory is the Data Principal, because business documents still hold personal data. The DPDP Rules 2025 phase in, with most operational duties due around May 2027. We build to them now, and consent is our basis for processing.

What we collect, when and why

Step	Data	Why	Kept for
Advisor, form, quote	Business type, city, size, GST status, needs. No name or ID is asked for	To recommend and price a bundle	Chat 90 days; a quote with no order 180 days
Accepting a quote	Mobile number, stored only as a keyed hash and its last 4 digits, shown masked	To save the application	With the owner record
KYC, after consent	Document images, the fields read from them, the signatory's name	To verify the business before activation	Images 30 days after verification, or deleted on rejection. Fields for the contract term, or 180 days with no active order
Optional	Consent for order updates, and separately for offers	Only if ticked	Until withdrawn

Consent and rights

- **Notice first, enforced on the server.** A KYC call without active consent returns 403 before anything is read or stored. Boxes start unticked, and each purpose is separate: business details, AI reading of chat, KYC, order updates and marketing. The short form works without the AI consent. Notices are in English and Hindi, and a new notice version asks again.
- **Withdrawal is as easy as granting.** My data states the effect first. Withdrawing KYC consent stops processing, deletes documents and cancels any order not yet active. On an active order, only raw documents go, and fields stay until the contract ends.
- **Rights.** My data shows what is held, and a grievance contact (a placeholder address in this prototype). Owners can correct a mismatched name and replace documents in verification. The owner must tick a declaration of being 18 or over and authorised, which is recorded but not otherwise checked.

What leaves the app

- **Only the advisor chat calls an outside service: Google Gemini, and only with the separate AI consent.** It receives chat text after GSTIN, Udyam, PAN, voter ID, UPI and email patterns, any run of 8 or more digits and "my name is" phrases are removed, plus business facts, and a brief to word that holds no chat text. Documents, OCR text, KYC data and the verified phone number are never sent.
- **Limits we state plainly.** Pattern removal can't catch everything: a name or an unusual ID typed into chat can get through, so the notice asks owners not to type them. Gemini may process data outside India. On its unpaid tier, *Google may use content to improve its products and its reviewers may read it*, which the notice discloses. Real customer data would need a paid tier and a data processing agreement.
- **The LLM decides nothing.** Code decides eligibility, prices and KYC verdicts. Chat is treated as untrusted: the model that words replies never sees it. A guard rejects any reply with its own numerals in any script, and with its own amounts in words, promises, comparisons or product names in English and Hindi. Prices on screen always come from code. The journey still completes with the LLM off.

Security controls

- **Documents.** Content-checked, with a PDF reduced to an image of its first page in a separate process with time and memory limits, re-encoded to strip metadata, read by OCR on our own server, and stored outside the database and web root with AES-256-GCM and a per-file key. Blurred or wrong documents aren't kept, and a rejection deletes images at once. Extracted fields and identity are sealed in the same way.
- **Access.** Signed HttpOnly session cookies with same-site checks, ownership checks on every object (another owner's object returns 404), random public IDs, strict request schemas, rate limits and idempotency keys. Admin routes share one separate token, with no roles yet.
- **Masking and logs.** Identifiers are masked on screen. The one exception is a GSTIN the owner must check against their own certificate. A name from our records is compared with the ID and never shown. Logs use an allowlist of fields, so a name or document value can't reach them.
- **Minimisation and retention.** ID numbers and consumer numbers on documents are never stored. KYC tables stay apart from analytics, the propensity score reads lead fields only, with no language, state or KYC tables, and the back office shows business facts with no documents, and its reads are audited. A retention job runs at startup and daily on a long-running server. Consent and audit records are append-only.

What is mocked or missing, and what production needs

Today	Production needs
OTP is a fixed test code, so anyone who knows a number can sign in as that owner	Real OTP through a telecom gateway, with device and IP limits
GSTIN and Udyam are local mock registries; payment and messages are labelled mocks with no card data	Licensed GST and Udyam APIs, DigiLocker, a payment gateway, and DLT-registered messaging
Master key in an environment file, on one server, one admin token, no script nonce in the content policy, no breach process, DPO or independent audit	A key management service, hosting in India, staff accounts with roles, a strict content policy, a breach runbook for the Board and owners, a named grievance officer, and a security audit